

The Engagement & Governance Kit

Rules of Engagement (RoE)

Client: Smith & Associates

1. **Scope of Work:**

The security evaluation is strictly limited to the assets explicitly defined below. Any asset not explicitly listed here is considered **Out-of-Bounds**.

In-Bounds IP Addresses

- Internal Network Subnet:
192.168.10.0/24 (Includes all workstations and internal servers located at the law firm's main office.)
- External IP Range:
203.0.113.45 through 203.0.113.60 (For testing the firm's firewalls and VPN)

In-Bounds Domains

- **Primary Public Web Domain:** smithlawfirm.com
- **All Associated Subdomains:** *.smithlawfirm.com (Specifically targeting the firm's mail server and client portal).

2. **Methods:**

To ensure network stability and data integrity, testing activities are strictly categorized into allowed techniques and prohibited actions.

Allowed Methods

- External Passive Scanning for Perimeter Defense:
 - Nmap (Map network and identify active host)
 - Shodan (Reveal open ports and publicly visible services)
- Internal Scanning & Vulnerability Assessments within trusted network:
 - Nessus (Identify security gaps and outdated software)
- Wireless Security Assessment:
 - Wireshark (Capturing local wireless traffic and performing packet analysis to evaluate encryption strength.)

Forbidden Methods

The following activities are strictly prohibited under this agreement. Engagement in any of these actions will result in immediate termination of the testing and potential legal liability:

- Denial of Service (DDoS) attacks:
Any actions designed to degrade, disrupt, or crash firm services or network infrastructure.
- Social Engineering:
Phishing, vishing, or manipulating Smith & Associates employees or clients.
- Physical Intrusion:
Attempting unauthorized physical entry into the firm's premises, offices, or server rooms.

3. **Data Handling:**

As a law firm, Smith & Associates possesses highly sensitive legal documents and

Personally Identifiable Information (PII). Will legally and technically protect all discovered data using the following framework:

- Data Encryption:
All sensitive files or PII (Personally Identifiable Information) discovered will be stored using AES-256 encryption.
- Data Redaction:
Any sensitive information (such as client names, case details, or financial records) included in the final report will be heavily redacted to ensure private legal content is not exposed.
- Secure Data Disposal:
All collected data, temporary files, and copies of legal documents will be deleted upon completion of projects.
- Confidentially:
Agrees to maintain strict confidentiality regarding all information shared, ensuring it is only shared with authorized contacts at Smith & Associates.

Part 2: Permission to Test (PTT)

Authorization Letter

To Whom It May Concern,

The purpose of this document is to formally authorize Sandy Nguyen (Cybersecurity), to conduct authorized penetration testing, vulnerability assessments, and security evaluations against the assets of Smith & Associates.

This authorization grants the above-named party permission to perform the following specific testing actions:

1. Conduct network and passive scanning using Shodan, Nmap and Wireshark.
2. Perform internal vulnerability scanning using Nessus to identify network security gaps.
3. Analyze active network ports, services, and system configurations for security weaknesses.

The scope of this permission is strictly limited to the activities outlined above. Any testing outside of these parameters requires separate, prior to written consent. All testing must be conducted in compliance with mentioning any relevant safety standards, confidentiality agreements, or guidelines.

This document is designed to prevent the detention or termination of the technician while performing authorized security duties.

Authorization Period: Valid and effective beginning **May 25, 2026**, and concluding on **May 25, 2027**.

By signing below, both parties agree to the scope, methods, and protections outlined in this multi-page Engagement & Governance Kit.

Signed and Authorized By:

Smith & Associates
Law Firm